

CSIT302 Cybersecurity

Day 3-1 – Malware and Attack Technologies

Subject Coordinators: Dr Partha Sarathi Roy
School of Computing and Information Technology

Outline

- **Malware Classification**
- Brief Introduction of Several Malwares
 - Virus, Worms, Trojans, Backdoor, Ransomware, ...
- Countermeasures for Malware Attacks

What is Malware?

- Malware is short for ‘Malicious Software’, that is, any program that performs malicious activities.
- NIST SP 800-83 (Guide to Malware Incident Prevention and Handling for Desktops and Laptops, July 2013):

“Malware (Malicious software) is a program that is inserted into a system, usually covertly, with the intent of compromising the confidentiality, integrity, or availability of victim’s data, applications or operating systems or otherwise annoying or disrupting the victim.”

The Damage Caused by Malware

- Malware carries out many of the cyberattacks on the Internet, including nation-state cyberwar, cybercrime, fraud and scams.
- For example:
 - Trojans can introduce a backdoor access to a government network to allow nation-state attackers to steal classified information.
 - Ransomware can encrypt data on a user's computer and thus making it inaccessible to the user and only decrypt the data after the user pays a sum of money.
 - Botnet malware is responsible for many of the Distributed Denial-of-Service (DDoS) attacks as well as spam and phishing activities.

Some Numbers

- According to Malware statistics 2024

(<https://dataprot.net/statistics/malware-statistics/>) :

- There are more than 1 billion malware programs out there.
- 560,000 new pieces of malware are detected every day.
- Three in four infected IoT devices are routers.
- Symantec: In 2020, the number of detected malware variants rose by 62%.
- Google: Each week, Google detects 50 websites containing malware.

Types of Malware

- There are many types of Malware, including:
 - Virus
 - Worms
 - Trojans
 - Spyware
 - Botnet Malware
 - Ransomware

Classification

- Malware can be classified into different categories depending on different characteristics, like
 - Need a host program or standalone
 - ✓ Viruses vs Worms and bots
 - Replicate or not
 - ✓ Viruses and Worms vs Trojans and spam e-mail
 - Variety of actions or payloads used when reached a target
 - ✓ Payload actions performed by malware once it reaches a target system can include corruption of system or data files
 - ✓ Corruption of system or data files vs Theft of service vs Theft of information etc.

Potentially Unwanted Programs (PUPs)

- A PUP is typically a piece of code that is part of a useful program downloaded by a user.
- E.g., Adware included in the, free version of a mobile game application
 - a form of PUP that displays ad banners on the game window
 - also collects user data (such as geo-location, time spent on the game, friends, etc.) without the user's knowledge and consent, in order to serve more targeted ads to the user to improve the effectiveness of the advertising.
 - is considered spyware as it defined as unwanted program that steals information about a computer and its users.
- PUPs are in a grey area!
- It should be classified as Malware from the point of view of Cybersecurity.

Outline

- **Malware Classification**
- **Brief Introduction of Several Malwares**
 - **Virus, Worms, Trojans, Backdoor, Ransomware,...**
- **Countermeasures for Malware Attacks**

Virus

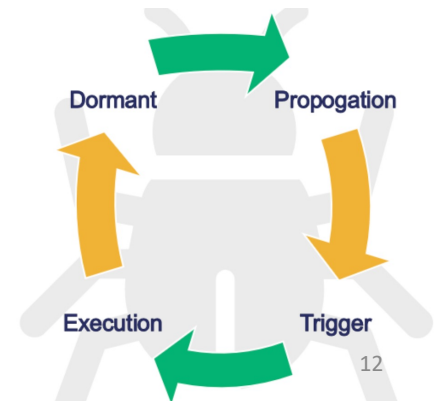
- A computer virus is a **piece of software** that can “infect” other programs, or indeed any type of executable content, by modifying them.
- It needs a host program or file to execute.
- Computer viruses first appeared in the early of 1980s.
- In earlier years, viruses dominated the malware scene due to the lack of user authentication and access controls on personal computer systems at that time.
- The tighter access controls on modern operating systems significantly hinders the ease of infection of viruses.
- This resulted in the development of macro viruses that exploit the active content supported by some documents types, such as Microsoft Word or Excel files, or Adobe PDF documents.

Virus: Basic Components

- Three main components of a virus:
 - **Infection mechanism:** The means by which a virus spreads or propagates, enabling it to replicate. The mechanism is also referred to as the infection vector.
 - **Trigger:** The event or condition that determines when the payload is activated or delivered, sometimes known as a logic bomb.
 - **Payload:** What the virus does, besides spreading. The payload may involve damage or may involve benign but noticeable activity.

Virus: Phases of its Lifecycle

- **Dormant phase:** The virus is idle. It may be waiting for a trigger before propagation begins. Not all viruses have this.
- **Propagation phase:** The virus places a copy of itself into other programs or into certain system areas on the disk.
- **Triggering phase:** The virus is activated to perform the function for which it was intended.
- **Execution phase:** The function is performed.



Virus: Initial Prevention

- Depending on the access permissions the infected program has,
 - a virus can potentially infect some or all the other files on the system with executable content
- The infection can be completely prevented by blocking the virus from gaining entry in the first place.
- Unfortunately, prevention is extraordinarily difficult because a virus can be part of any program outside a system.
- Many forms of infection can also be blocked by denying normal users the right to modify programs on the system

Classification of Virus

- No simple or universally agree-upon classification scheme for viruses.
- Here we give two classifications based on:
 - the type of target the virus tries to infect
 - the method used to conceal itself from detection

Classification by Targets

- **Boot sector infector** : Infects a master boot record or boot record and spreads when a system is booted from the disk containing the virus.
- **File infector**: Infects files that the operating system or shell consider to be executable.
- **Macro virus**: Infects files with macro or scripting code that is interpreted by an application.
- **Multipartite virus**: Infects files in multiple ways, infecting multiple type of files.

Classification by Concealment Strategy

- **Stealth virus:** designed to hide itself from detection by anti-virus software. Thus, the entire virus, not just a payload, is hidden.
- **Encrypted virus:** use encryption to obscure its content
- **Polymorphic virus:** change form each time they are inserted into another program.
- **Metamorphic virus:**
 - a higher order of polymorphic viruses.
 - Not only do they change in form between transitions they can be completely re-written

An example virus

```
program CV :=  
{goto main;  
 01234567;  
  
  subroutine infect-executable :=  
    {loop:  
      file := get-random-executable-file;  
      if (first-line-of-file = 01234567) then goto loop;  
      (1)   compress file;  
      (2)   prepend CV to file;  
    }  
  
main:  main-program :=  
      {if ask-permission then infect-executable;  
      (3)   uncompress rest-of-file;  
      (4)   run uncompressed file;}  
    }
```

Worms

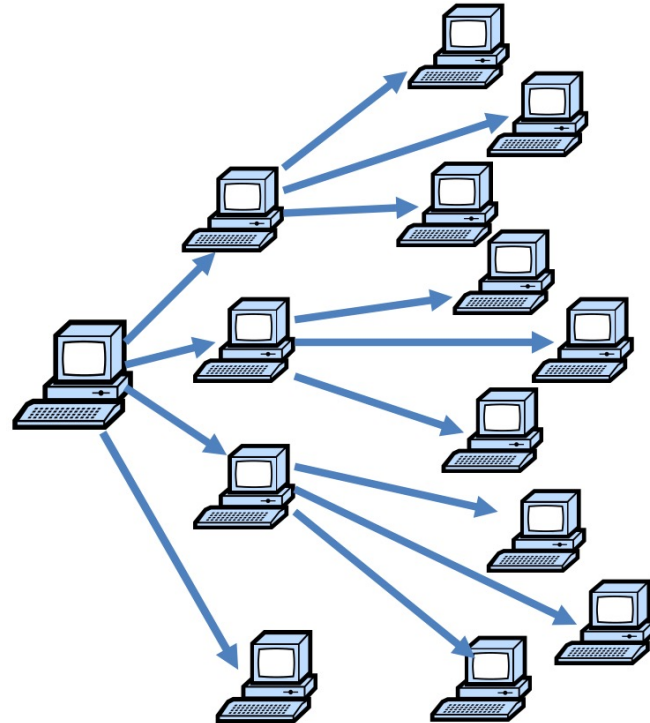
- **Worm**: a program that **self-propagates/replicates** across systems by arranging to have itself immediately executed, creating additional, new instances of itself.
- **Worm** programs usually exploit software vulnerabilities in client or server programs to gain access to each new system.
- It is standalone and does not need a host program.

Worms' replication

- **Electronic mail or instant messenger facility:** A worm e-mails a copy of itself to other systems, or sends itself as an attachment via an instant message service
- **File sharing:** A worm either creates a copy of itself or infects other suitable files as a virus on removable media such as a USB drive
- **Remote execution capability:** A worm executes a copy of itself on another system, either by using an explicit remote execution facility or by exploiting a program flaw in a network service to subvert its operations
- **Remote file access or transfer capability:** A worm uses a remote file access or transfer service to another system to copy itself from one system to the other
- **Remote login capability:** A worm logs onto a remote system as a user and then uses commands to copy itself from one system to the other

Rapid Propagation

- Worms can potentially spread quickly because they parallelize the process of propagating.
- Same holds for viruses, but they spread slowly since they require some sort of user action to trigger each propagation.



The Morris Worm

- One of the first computer worms distributed via the internet
- Was released onto the Internet by Robert Morris in 1988
- Was designed to spread on UNIX systems
- Within 24 hours, an estimated 6,000 of the approximately 60,000 computers that were then connected to the Internet had been hit.
- The worm did not damage or destroy files, but:
 - vital military and university functions slowed to a crawl
 - Emails were delayed for days.
- More detail: [SB18] and <https://www.fbi.gov/news/stories/morris-worm-30-years-since-first-major-attack-on-internet-110218>

Trojan Horse

- Software that appears to perform a desirable function but is actually designed to perform undisclosed malicious functions.
- It is not self-replicate



Trojan Technology

- Some concealment methods:
 - A Trojan renames itself to the name of a valid system file.
 - They can also be encrypted and polymorphic, and could install themselves in different ways to escape detection.

An Example of Trojan

A simplified pseudo-code of Trojan Horse Disguised as File Downloader.

Code

```
// Trojan Horse Pseudo-Code (Disguised as a File Downloader)

// 1. Appear to be a File Downloader
DISPLAY "Downloading file..."

// 2. Secretly Install Malicious Code
// Instead of downloading a real file,
// execute a malicious script or install malware
EXECUTE_MALICIOUS_CODE()

// 3. Display a Fake Download Completion Message
DISPLAY "Download complete!"

// 4. (Optional) Clean up any traces
// Delete the fake download file
DELETE_FAKE_FILE()

// Malicious Code Execution (Hidden Function)
FUNCTION EXECUTE_MALICIOUS_CODE()
    // Example: Install a backdoor or steal data
    INSTALL_BACKDOOR()
    // OR
    STEAL_DATA()
END FUNCTION

// Optional: Delete the fake file
FUNCTION DELETE_FAKE_FILE()
    // Delete the fake file
    DELETE_FILE()
END FUNCTION
```

Logic Bombs

- A program that performs an malicious action when some external event occurs.
- It is embedded in the malware that is set to “explode” when certain conditions are met.
- Examples of conditions that can be used as triggers for a logic bomb are:
 - presence or absence of certain files or devices of the system;
 - a particular day of the week or date;
 - a particular version or configuration of some software;
 - A particular user running the application
- Once triggered, it may alter or delete data or files, cause machine or other damage.

A toy example for timer logic bomb

Code



```
IF (current_date = "April 1 2025") THEN  
    // Perform malicious action (e.g., delete files)  
    DELETE_ALL_FILES()  
ENDIF
```

Backdoor

- Backdoor (Trapdoor) is a secret entry point into a program that allows someone to gain access without going through the usual security access procedures
 - Programmers used backdoor to debug and test programs
 - But can be used to gain unauthorised access
- A backdoor is usually implemented as a network service listening on some non-standard port that the attacker can connect to and issue commands through to be run on the compromised system
 - The WannaCry ransomware included such a backdoor
 - See: <https://www.kaspersky.com.au/resource-center/threats/ransomware-wannacry>
- It is difficult to implement operating system controls for backdoors in applications.

Ransomware

- From the Symantec report (April 2015)
- “Ransomware attacks grew 113 percent in 2014, along with 45 times more crypto-ransomware attacks.” ~ 24,000 per day...
- Ransomware typically involves an attack on availability that will not be stopped until some payment is made.
 - Crypto-ransomware involves encrypting files.
 - When you pay, you get the password/key.

Outline

- **Malware Classification**
- **Brief Introduction of Several Malwares**
 - **Virus, Worms, Trojans, Backdoor, Ransomware,...**
- **Countermeasures for Malware Attacks**

Countermeasures

- Malware acts as both data and instructions:
 - A virus inserts code (a set of instructions) into another program.
 - The set of instructions is treated as data.
 - The virus executes itself, the set of instructions is treated as an executable.
 - Protection:
 - ✓ Treat all programs as type "data".
 - ✓ Some certifying authority can change the type to executable, after verification takes place.

Countermeasures

- Against Malicious code assuming the identity of a user:
 - When a user executes malicious code, that code can access and affect objects within the user's protection domain.
 - Protection: Limiting the objects accessible to a given process run by the user.
 - ✓ Reducing the Rights.
 - ✓ Sandboxing.

More on defence

- **Sandboxing** can be used.
 - Virtual environments.
 - ✓ From Symantec report (April 2015).
 - “In 2014, up to 28 percent of all malware was “virtual machine aware.””
- Restrict sharing by controlling the domain boundaries:
 - Restrict users in different protecting domains from sharing programs or data.
 - Programs to be protected should be placed at the lowest level of an implementation of a multilevel security policy.

Detection

- Normal behaviour of a system is usually different from the activity profile of an infected system.
 - Virus monitors monitor known methods of virus activity, such as attempts to write to a boot sector, modify interrupt vectors, write to system files... and detect abnormal behaviour of the system.
- **Advantages:**
 - Works for all viruses.
 - Detection is before (complete) infection.
- **Disadvantages:**
 - To detect a high percentage of viruses, the sensitivity of the monitor must be set high and this may generate many false alarms.

Multiple copy testing ...

- Run several copies of the “same program or algorithm”.
 - This is not simply running the same program several times.
- Majority rules...
- The check could be based on results, calls made, efficiency ...
- Majority still might not be trusted, because they might all be corrupted.
- But different performances can imply action needs to be taken.

Signature scanning

- Signature scanning (signature= search string= scan string) is the simplest and the most common approach to virus detection.
- Signature extraction is a non-trivial process:
 - The infection is disassembled and the key portions are identified.
 - The key portions are combined to form a signature.
 - The signature is checked against a large library of programs to reduce the chance of false positives occurring when signature accidentally matches some library code

Signature scanning

- **Advantages:**

- Signature scanning can be used against Trojan horses, logic bombs and other malicious software.

- **Disadvantage:**

- Scanning cannot find new viruses before their patterns are known.
- It is also ineffective against polymorphic viruses.

- First-generation scanner's use virus signatures only.

- GPU's can be used to speed up signature processing!

<https://developer.nvidia.com/gpugems/gpugems3/part-v-physics-simulation/chapter-35-fast-virus-signature-matching-gpu>

2nd, 3rd and 4th generation scanners

- **Second generation** scanners don't just use specific signatures, since the signatures of many viruses change (polymorphic).
 - User heuristic rules to search for probable malware instances
 - Integrity checks (e.g. checksum) can also be applied
- **Third generation** scanners detect viruses by behaviour.
 - For example, attempts to interact inappropriately with certain system files could trigger detection.
- **Fourth generation** basically use a collect of antivirus techniques together.
- One quite important, and fairly new tool, is virtualisation.
 - We can run a virus in an isolated but realistic environment and see what happens

Reference & Recommended Reading

William Stallings and Lawrie Brown, Computer Security: Principles and Practice, 4th Edition. Pearson, 2018. **(Chapter 6)**